

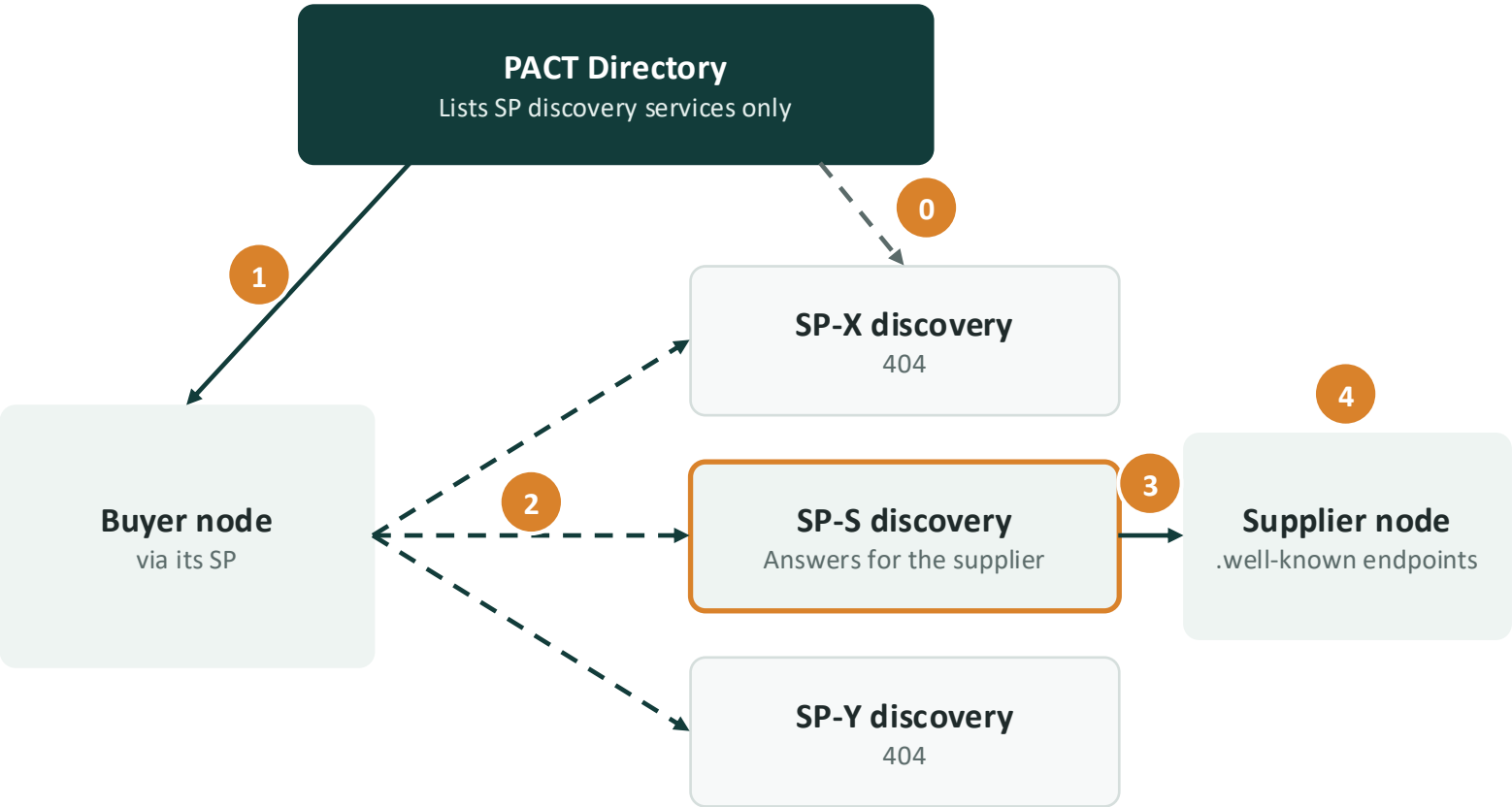


Tech WG Discoverability, Connectivity

Session: 2026-09-16

How discovery works

A buyer looks up a supplier it has never exchanged with, across platforms, without any central index of companies (§5).



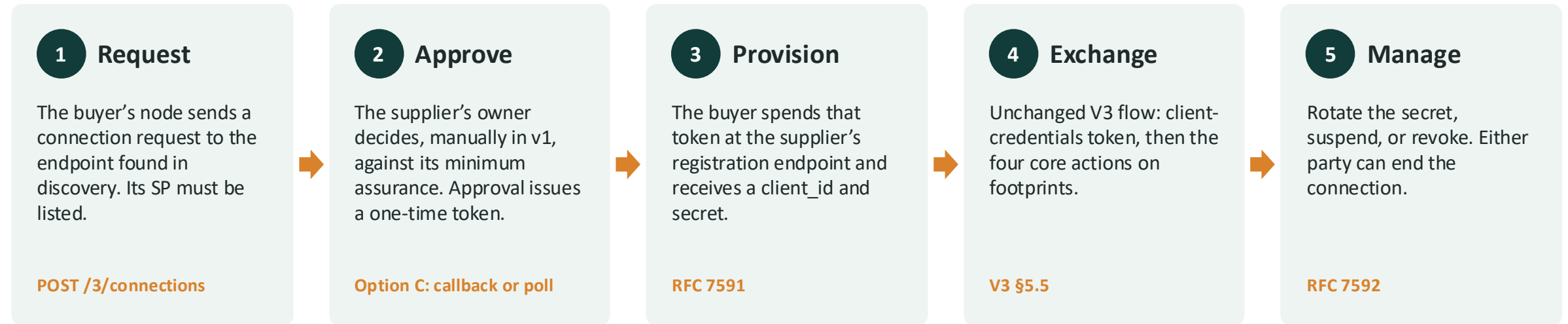
- 0 SPs get listed**
Pass the discovery conformance test, including a domain-ownership check
- 1 Fetch the Directory list**
Active discovery services only; suspended ones are skipped
- 2 Fan out by companyIds URN**
Query every listed service; one identifier per query
- 3 The supplier's SP answers**
Nodes, assurance level with evidence, and who attests. Others return 404, whether unknown or not opted in
- 4 Read the supplier node**
Token and registration endpoints come from its own .well-known, never from discovery

Option A2: the PACT Directory runs step 2 on the buyer's behalf and keeps nothing.

SP-side cost: 1 new method, GET /3/discovery?companyId=

Connecting and credential exchange

From “found” to “exchanging” without passing client credentials by hand. Strictly peer-to-peer: PACT is not a party (§6).



Connection states



Also: declined, or expired if undecided or the token goes unused

Open: how is the request authenticated? (decision C)

- C1** Approval and token go only to the buyer endpoint its SP publishes
- C2** Request signed with the buyer SP's domain key; buyer polls for the decision

Always true

- Being found is never being connected
- Credentials go node to node only
- V3 token flow untouched
- Delisting is not revocation
- Both directions = two connections
- No PACT service needs to be online

What changed after the 2 September session

The drafts still described the June architecture. The four WG decisions are now written into the spec.

Decided 2 Sept

June draft

16 Sept draft

1	Directory of SP endpoints only	Federated, LEI-keyed index of every company, with regional roots and delegations	➔	PACT lists only SP discovery endpoints. Company data stays with each SP. Regional roots become a future note.
2	SP identity via domain ownership	Registration never gated on conformance; the registry checks endpoint control	➔	Listing requires the discovery conformance test, including a domain check. V3 conformance stays an attribute.
3	LEI becomes an optional layer	LEI the recommended canonical identifier; vLEI the verified tier	➔	Any companyIds URN. LEI and verifiable credentials (vLEI as one profile) are optional, stronger layers.
4	Email or domain is enough	Three assurance levels: self-asserted, LEI-verified, vLEI-verified	➔	Five levels, adding email- and domain-verified. Each company's own SP checks and vouches for it.

What's in the draft now

Working drafts in the IM spec repository. Nothing is ratified; positions awaiting WG confirmation are marked in the decisions log.

UPDATED

§3 Identity Model

LEI optional, five assurance levels, and the verification options side by side

REWRITTEN

§4 Registration

PACT Directory of SP endpoints, with conformance-gated listing and a domain check

NEW

§5 Discovery

Lookup by companyIds across SPs, why a directory rather than DNS, options A and B

NEW

§6 Credential Exchange

First pass: request, approve, RFC 7591 provisioning, rotate and revoke; option C

NEW

§10 API

Endpoints for SPs, an OpenAPI 3.1 fragment, and the method count per option

UPDATED

Flow diagram

End-to-end sequence from SP listing to exchange, with options A and C shown

UPDATED

Brief and decisions log

2 Sept decisions, drafting positions to confirm, and open options A–C

Unchanged

- PACT not in credential or data path
- V3 data model and token flow intact
- Every connection needs approval
- Delisting is not revocation

Discovery: two decisions to be made

Agreed 2 Sept: PACT lists SP discovery endpoints only · party data stays with each SP · lookup by companyIds · listing needs domain ownership + discovery conformance

● advantage ● cost



Who does the fan-out?

Draft addendum §5.5

Would you rather competing SPs see your customers' lookups, or PACT?

A1 Your platform queries every SP

- Every SP sees each lookup
- PACT only publishes a list
- Still works if PACT is down
- Fan-out and merging in every client

A2 PACT Directory queries on your behalf

- Only PACT sees lookups, retains nothing
- PACT in the discovery path (never data)
- Discovery stops if PACT is down
- One call for clients



Who may query an SP?

Draft addendum §5.6

*Is protecting your customer list worth one key pair per SP?
Also settles: registry access public or conformant-only.*

B1 Listed SPs only, signed requests

- Every query attributable to a listed SP
- Customer lists protected from harvesting
- Key pair, JWKS and signing for every SP
- Only parties behind a listed SP can search

B2 Public, minimal answer

- No keys; anyone can discover
- Simplest to build and test
- Anyone can map which SP serves whom
- Answer limited to endpoint + assurance

Connecting: one decision, four positions to confirm

A connection request arrives before any credentials exist. How do we know it is genuine?

● advantage ● cost



How is a connection request authenticated?

Draft addendum §6.4

C1 Approval sent only to the published endpoint

- No cryptography beyond TLS
- Decision pushed when owner approves
- Requester must be discoverable
- Impersonators can file useless requests

C2 Signed request, requester polls

- Impersonation not possible
- Requester need not be discoverable
- Key pair and request signing per SP
- Decision must be polled

Decide B and C together

B2 + C1 No keys anywhere, simplest to build

B1 + C2 One key pair per SP, used for both

3

new PACT API methods per SP, whichever options are chosen, plus standard OAuth RFC 7591/7592

Confirm today

Positions taken while drafting (§12.2)

- 1 Discoverability is explicit opt-in**
By identifier only; changes June default
- 2 Your SP vouches for its customers**
Publishes what it checked and when
- 3 Self-hosted company = SP of one**
Same listing and tests, no special case
- 4 Open: SP portability**
Does leaving an SP still need a rule?